AetherGuard

Root-Resistant Gateway Appliance

自研工业级硬件最后防线一体机

Multi-port Gateway + Security Authorization Controller
+ Secure Element / TPM + Fail-closed Interlock

让每一台服务器，拥有自主免疫能力

中国国际大学生创新大赛（2026）· 高教主赛道 · 本科生创业组

AetherGuard 大学生创新创业项目组

版本 v1.0 | 2026 年 6 月

目录

一、执行摘要

二、背景与问题

三、产品概述

四、系统架构

五、核心模块 M1：Multi-port Gateway（工业多网口网关）

六、核心模块 M2：Security Authorization Controller（安全授权控制器）

七、核心模块 M3：Secure Element / TPM（安全芯片 / 可信平台模块）

八、核心模块 M4：Fail-closed Interlock（硬件级闭锁机制）

九、硬件代际演进：从 ESP32 到 Gateway Appliance

十、安全模型与 Root-resistant Active 判定

十一、竞品对比与市场定位

十二、产品路线图

十三、总结

一、执行摘要

AetherGuard Root-Resistant Gateway Appliance 是面向服务器失陷场景的自研工业级硬件最后防线一体机。它将关键网络释放权从被保护服务器的软件系统中移出，交给外部独立的硬件安全一体机执行。即使攻击者获取服务器 root 权限，也无法仅凭服务器自身权限恢复 SERVER 与 LAN/WAN 之间的关键网络连接。

Appliance 由四大核心硬件模块组成：工业多网口网关（Multi-port Gateway）、独立安全授权控制器（Security Authorization Controller）、安全芯片 / 可信平台模块（Secure Element / TPM）和硬件级闭锁机制（Fail-closed Interlock）。四大模块协同工作，实现默认隔离、硬件授权、状态反馈和全链路审计的 root-resistant 最终防线。

> "AetherGuard 把服务器的最后一道网络开关，放到服务器外面——用一台自研的硬件安全一体机。"

本 Appliance 全面替代此前的 ESP32 硬件信任根方案，从串口部署 dongle 升级为具备双千兆数据口、独立管理通道和物理级网络隔离能力的一体机，标志着 AetherGuard 硬件防御能力从原型验证阶段进入工业级产品化阶段。

二、背景与问题

传统服务器安全产品（Agent、EDR、WAF、自动化运维工具等）主要运行在被保护服务器内部或同一软件信任边界中。当攻击者获得服务器 root 权限后，可能出现以下威胁：

- 停止安全 Agent，使主机层防御失效
- 篡改系统日志和审计记录，掩盖入侵痕迹
- 修改本机防火墙规则，开放非授权网络通道
- 绕过本机隔离策略，恢复横向移动能力
- 伪造健康状态，欺骗集中式监控平台
- 重新打开网络连接，建立持久化后门
- 执行破坏性运维操作（数据擦除、系统重置等）

上述威胁的共同特征是：它们都发生在服务器内部的软件信任边界之内。一旦 root 权限失守，所有运行在该边界中的安全措施都可能被绕过。这就是 AetherGuard Final Defense Mode 要解决的核心问题——在入侵已发生后，提供一条外部、可审计、默认隔离的硬件最后防线。

此前 AetherGuard 采用 ESP32 系列开发板作为硬件信任根的载体，通过串口（USB-TTL）实现物理确认功能。该方案在原型验证阶段有效证明了安全模型的可行性，但存在明显的产品化瓶颈：无独立网络接口（无法控制数据平面）、通用 MCU 缺乏专用安全引擎、安全芯片选型单一、隔离机制依赖软件层面。为了将安全能力从"原型验证"提升到"工业级产品"，AetherGuard 团队决定全面退役 ESP32 方案，推出自研的 Root-Resistant Gateway Appliance。

三、产品概述

3.1 产品定位

AetherGuard Root-Resistant Gateway Appliance（简称 AG Appliance）是部署在关键服务器外部的自研工业级硬件最后防线一体机。它不是传统防火墙的替代品，也不是 EDR 的替代品，而是在现有安全产品之外增加的一层可审计的外部硬件控制边界。

产品是什么

- 部署在服务器外部的网络隔离边界
- 默认 fail-closed 的外部网关
- 具有独立 MGMT 通道的安全控制点
- 由 Secure Element 和安全 MCU 保护最终授权逻辑的硬件最后防线
- 能把状态、授权、反馈、审计上传到 AetherGuard 控制平面的安全设备

产品不是什么

- 传统防火墙或 EDR 的替代品
- 普通 OpenWrt 路由器
- 单纯的远程继电器
- 承诺永不被攻破的绝对安全设备

3.2 核心价值主张

价值维度	说明
失陷后控制	假设服务器已被 root，仍保留外部网络隔离能力
默认安全	默认 isolated，释放需要明确授权
硬件授权	高危操作不能只靠后端 API 或主机脚本决定
可审计	每次 release 都有 challenge、counter、signature、feedback 记录
可验证	Dashboard 实时展示 root-resistant active 的具体条件

价值维度	说明
可集成	不替代现有安全产品，可与 EDR、防火墙、堡垒机共存

四、系统架构

AetherGuard Gateway Appliance 采用"三平面 + 四模块"架构。三平面指数据平面（SERVER □ LAN/WAN）、管理平面（MGMT □ Backend）和控制平面（Controller □ Gateway Daemon □ Backend）。四模块指 M1 工业多网口网关、M2 安全授权控制器、M3 安全芯片/TPM 和 M4 硬件级闭锁机制。

4.1 通信路径

路径	协议 / 接口	说明
Backend □ M1	HTTPS / WebSocket	经 MGMT 独立管理通道，不经过数据平面
M1 Gateway Daemon □ M2 Controller	Serial JSON (UART/USB-CDC/RS485)	release 请求、heartbeat、状态上报
M2 Controller □ M3 Secure Element	I2C / SPI	签名运算、密钥操作、设备身份
M2 Controller □ M4 Interlock	GPIO + 光耦隔离	relay 驱动 + feedback 读取
SERVER □ LAN/WAN	GbE L2 透明桥接	受 nftables + interlock 双重控制

4.2 关键安全原则

M1 Gateway Linux 可以请求 release，但不能单方面完成最终 release。最终 release 必须经过 M2 Security Controller 状态机、M3 Secure Element 签名验证和 M4 Interlock 物理反馈闭环。这一设计确保了即使网关 Linux 被攻击者完全控制，也无法绕过硬件安全边界。

五、核心模块 M1：Multi-port Gateway

工业多网口网关 — 数据平面与管理平面承载平台

M1 是 Appliance 的网络基础设施层，运行嵌入式 Linux 操作系统，承担 SERVER □ LAN/WAN 的透明 L2 桥接 / 防火墙控制，以及通过独立 MGMT 口与 AetherGuard 后端通信。

5.1 硬件规格

参数	要求
CPU	x86（Intel Celeron / Atom）或 ARM（NXP i.MX8 / RK3568）
内存	≥ 4 GB DDR4 / DDR5
存储	≥ 32 GB eMMC / NVMe SSD
网口	≥ 3 个物理 GbE RJ45：SERVER、LAN/WAN、MGMT
扩展	可选 SFP/SFP+ 用于 10G 上联；可选 4G/5G M.2 模块
TPM	可选板载 TPM 2.0（与 M3 Secure Element 互补）
OS	Debian 12+ / OpenWrt 23+ / OPNsense / VyOS
Watchdog	硬件 watchdog，固件挂死时驱动 bridge 回落到 isolated
供电	12V DC 或 19V DC，支持冗余电源输入
工作温度	0°C ~ 50°C（工业级），可选 -20°C ~ 60°C
外形	无风扇被动散热，DIN-rail 或 1U 机架安装

5.2 软件组件：Gateway Daemon

Gateway Daemon 是运行在 M1 嵌入式 Linux 上的核心守护进程，负责以下职责：

- 向 AetherGuard 后端注册身份、端口信息、控制器状态和 Secure Element 状态
- 管理 SERVER □ LAN/WAN 的 nftables / iptables 桥接和防火墙规则
- 通过 Serial JSON 协议与 M2 安全控制器通信

- 只在 interlock released 且 feedback 一致时才打开 bridge
- 周期性上报状态到后端（heartbeat 间隔 1-5 秒）
- 本地审计日志缓存（环形缓冲区 + 远程同步）

六、核心模块 M2：Security Authorization Controller

独立安全授权控制器 — 最终授权决策引擎

M2 是 Appliance 的最终授权决策引擎，独立于网关 Linux 运行。即使网关 Linux 被攻破，M2 仍能独立执行 fail-closed，确保安全模型不被破坏。

6.1 芯片选型对比

参数	STM32H563（首选）	STM32U575	NXP LPC55S69
内核	Cortex-M33	Cortex-M33	Cortex-M33
主频	250 MHz	160 MHz	150 MHz
Flash	2 MB	1 MB	640 KB
RAM	640 KB	786 KB	360 KB
安全特性	TrustZone, HASH, AES, PKA	TrustZone, AES, PKA, PUF	TrustZone, AES, SHA, PUF
接口	SPI, I2C, UART, USB, GPIO	SPI, I2C, UART, USB, GPIO	SPI, I2C, UART, USB, GPIO

6.2 十二项核心任务

M2 安全控制器承担以下 12 项核心任务：

1. 接收 Gateway Daemon 的 release request（Serial JSON 协议）
2. 校验 challenge（不允许复用）
3. 校验 policyDigest（必须匹配本地已签名策略）
4. 校验 monotonic counter（不允许回滚）
5. 校验 expiry（过期拒绝）

6. 驱动 Secure Element 执行签名或身份验证

7. 读取物理确认按钮状态（支持 button timeout）

8. 控制 interlock output（relay 驱动）

9. 读取 feedback input（辅助触点反馈）

10. 周期性发送 heartbeat 到 Gateway Daemon

11. 上报完整 state 到后端（通过 Gateway Daemon 转发）

12. 支持 emergency stop（紧急停止按钮中断一切操作）

七、核心模块 M3：Secure Element / TPM

安全芯片 / 可信平台模块 — 硬件信任根

M3 是 Appliance 的硬件信任根，保护设备私钥和 grant 签名密钥，确保设备身份不可伪造、授权签名不可抵赖。M3 由两个互补的子模块组成：必选的 Secure Element 和可选的 TPM 2.0。

7.1 Secure Element 选型对比

特性	OPTIGA Trust M（首选）	SE050	ATECC608B	STSAFE-A110
算法	ECC-256/384, RSA, AES	ECC-256/384/521, RSA, AES	ECC-256, AES	ECC-256
密钥存储	非导出, 4 KB	非导出, 可扩展	非导出, 16 slots	非导出
接口	I2C	I2C	I2C / SPI	I2C
认证	CC EAL6+	CC EAL6+	CC EAL5+	CC EAL5+
温度	-25°C ~ 85°C	-25°C ~ 85°C	-40°C ~ 85°C	-25°C ~ 85°C

7.2 Secure Element 核心职责

- 保存设备私钥（非导出，仅在 SE 内部完成签名运算）
- 生成或验证 grant 签名（ECDSA P-256 over SHA-256）
- 绑定设备身份（唯一设备标识符 + 公钥证书）
- 支持 provisioning workflow（密钥注入、证书链建立）
- 支持后续 mTLS / device certificate 扩展
- 支持 monotonic counter 硬件实现

7.3 签名消息格式

Grant 签名基于 15 字段 newline-joined 消息，覆盖完整的授权上下文：

字段	说明
gateId / sessionId / actionId	标识网关、会话和操作
tenantId / scope / targetId	多租户与作用域控制
commandType / payloadHash	命令类型与负载完整性
policyDigest / challenge	策略绑定与防重放
breakerTarget / interlockAction	断路器目标与闭锁动作
issuedAt / expiresAt	时间窗口约束
monotonicCounter	单调递增计数器，防止回滚

7.4 可选 TPM 2.0

位于 Gateway 主板的 TPM 2.0 模块（如 Infineon SLB 9670 / ST33TPHF2X）与 Secure Element 互补，提供平台级度量启动（Measured Boot）、固件完整性度量、TPM quote 远程 attestation 以及可选的通信密钥 NV RAM 存储能力。

八、核心模块 M4：Fail-closed Interlock

硬件级闭锁机制 — 物理执行层

M4 是 Appliance 的物理执行层，通过硬件 relay 和 feedback 闭环实现"默认断开、授权闭合、异常回落"的 fail-closed 原则。这是整个安全模型的物理保障——即使所有软件层都被攻破，M4 仍能确保网络隔离的物理执行。

8.1 组件清单

组件	规格	职责
DIN-rail relay	24V DC, SPDT/DPDT, 额定 10A	物理控制 SERVER □ LAN/WAN 通断
隔离数字输出	光耦隔离, 24V 驱动	安全控制器驱动 relay
隔离数字输入	光耦隔离, 24V 兼容	读取 feedback 辅助触点
Feedback 辅助触点	与主触点机械联动	反馈 relay 真实物理状态
Emergency stop	常闭触点, 红色蘑菇头	一键切断所有 release
Confirmation 按钮	瞬时触点, 绿色	物理确认授权操作
Stack light 塔灯	三色 + 蜂鸣器	实时指示 Appliance 状态

8.2 Bridge 状态机

Appliance 的 bridge 状态机定义了四种状态及其转换关系：

状态	含义	转换条件
isolated	默认断开，SERVER □ LAN/WAN 无转发	启动默认 / 异常回落 / window 到期
armed	已验证释放请求，等待物理确认	release request 通过校验
released	interlock 已释放，允许转发	物理确认通过 / 自动授权
fault	检测到硬件异常或 feedback 不一致	feedback mismatch / heartbeat loss

8.3 九类自动隔离触发器

以下任何条件发生时，系统自动保持或回落到 isolated 状态：

1. Secure Element 签名验证失败
2. Monotonic counter 回滚检测
3. policyDigest 与本地已签名策略不匹配
4. Grant 有效期到期（expiresAt）
5. Secure Element 不可用或通信中断
6. Feedback 辅助触点状态与期望不一致
7. Controller heartbeat 丢失（> 45 秒无心跳）
8. MGMT 独立管理通道不健康
9. Gateway Daemon 与 Controller 状态冲突

九、硬件代际演进

AetherGuard Root-Resistant Gateway Appliance 全面替代此前的 ESP32 硬件方案。下表从八个维度对比了两代方案的能力差异：

维度	前代：ESP32 方案（已退役）	当前：Gateway Appliance
硬件形态	ESP32-WROOM-32 串口 dongle / ESP32-S3 控制板	工业级多网口网关一体机
网络能力	无（仅 USB-TTL 串口）	双 1GbE 数据口 + 独立 MGMT + 可选蜂窝
安全控制器	ESP32-S3（通用 MCU）	STM32H5/U5 专用安全 MCU（Cortex-M33）
安全芯片	ATECC608C（单一选型）	OPTIGA / SE050 / ATECC608B / STSAFE 多选型
隔离机制	软件管理链路隔离	硬件级 relay + feedback 闭环 fail-closed
信任根	ESP32 内部 flash	独立 Secure Element + 可选 TPM 2.0
数据平面	无	SERVER □ LAN/WAN 透明 L2 桥接 / 防火墙
产品化	跳线原型 / 开发板	工业网关 + 安全控制板 + DIN-rail 集成

代际演进的核心意义在于：从"原型验证安全模型可行性"跨越到"工业级产品化验证"。前代 ESP32 方案证明了"物理确认 + 硬件信任根"的安全模型在概念上可行；当前 Appliance 方案则将这一模型落地为具备网络隔离能力、工业级可靠性和完整授权链的产品。

十、安全模型与 Root-resistant Active 判定

AetherGuard Dashboard 只有在满足全部 12 项条件时，才会显示 "Root-resistant Active" 状态。任何一项条件不满足，将显示 "Root-resistant Degraded" 并附带具体原因。

序号	判定条件	说明
1	External gateway present	Appliance 已注册且在线
2	SERVER 口 link up	被保护服务器网线已连接
3	LAN/WAN 口 link up	上行网络已连接
4	MGMT 独立通道 healthy	管理通道独立可达
5	Secure Element provisioned	安全芯片已完成密钥注入
6	Controller heartbeat healthy	安全控制器心跳正常（1-5 秒间隔）
7	Gateway daemon healthy	网关守护进程运行正常
8	policyDigest matched	本地策略摘要匹配
9	Firmware digest / attestation	固件度量匹配（MVP 可标记 simulated）
10	Bridge state = isolated / armed	桥接处于安全的默认状态
11	Feedback 一致	interlock 反馈与期望状态一致
12	Counter 未回滚	最近一次单调计数器无回滚

当状态为 Degraded 时，Dashboard 会显示具体原因列表，例如："Secure Element not provisioned"、"Feedback mismatch"、"MGMT path unhealthy" 等。这使得安全运维人员能够立即定位问题并采取措施。

十一、竞品对比与市场定位

AetherGuard Gateway Appliance 在"智能化程度"和"安全防护能力"两个维度上占据右上角位置。以下是与现有方案的对比：

方案类型	代表产品	智能化	防护能力	自主可控	与 Appliance 差异
传统杀软	Symantec / 卡巴	低	低	部分	规则驱动，无 AI 自治
防火墙	Palo Alto / 深信服	中	中	部分	边界防御，无失陷后防线
EDR / XDR	CrowdStrike / 奇安信	中高	中	部分	检测增强，缺乏硬件授权
国外 AI 安全	SentinelOne / Darktrace	高	中高	不足	技术先进，国产化合规不足
AetherGuard	Gateway Appliance	高	高	完全	AI 自治 + 硬件信任根 + 国产化

AetherGuard 的差异化优势在于三个维度的叠加：AI 自治能力（Multi-Agent 态势感知 + AI 决策）、硬件信任根（Secure Element + 物理确认 + interlock 闭环）和国产化合规（国产芯片 + 国产 OS 兼容 + 等保合规支持）。目前市场上没有一款产品同时覆盖这三个维度。

十二、产品路线图

Appliance 的产品路线图分为五个阶段，从硬件采购到产品化评估：

阶段	周期	核心交付
Phase 0 硬件台架搭建	1-2 周	Protectli / 工业网关采购 STM32H5/U5 控制器 Secure Element 评估板 Relay / feedback / 按钮 / 塔灯 初始接线图
Phase 1 Final Defense 控制环	2-4 周	Controller heartbeat 实现 Serial JSON 协议栈 Button confirmation 流程 Interlock output + feedback input 后端状态接入 + UI 状态显示
Phase 2 网关网络隔离	2-4 周	SERVER / LAN/WAN / MGMT 三口配置 Bridge isolated / released 控制 Release window + fail-closed Audit log + Dashboard demo flow
Phase 3 安全芯片集成	2-4 周	Device identity 绑定 Grant signature 签名/验签 Monotonic counter + challenge policyDigest 策略绑定 Provisioning script
Phase 4 Root-resistant Demo	2 周	完整演示脚本 + 攻击模拟 演示视频 + 技术白皮书 客户 PoC 材料
Phase 5 产品化评估	4-8 周	自研控制板 BOM 量产硬件架构设计 Secure boot 方案 PHY/switch-level interlock 认证路径 + 成本评估

十三、总结

AetherGuard Root-Resistant Gateway Appliance 代表了服务器安全防御范式的一次重要演进：将最终的网络释放权从被保护服务器的软件信任边界中移出，交给外部独立的硬件安全一体机执行。

通过四大核心模块的协同——M1 工业多网口网关承载数据平面和管理平面、M2 STM32H5/U5 安全控制器承担最终授权状态机、M3 Secure Element / TPM 提供硬件信任根和签名能力、M4 硬件级 fail-closed interlock 确保物理执行层的隔离可靠性——Appliance 实现了一个可验证、可审计、默认隔离的 root-resistant 最终防线。

从 ESP32 原型到工业级一体机的代际演进，标志着 AetherGuard 从"验证安全模型"进入"产品化交付"阶段。面向高校科研服务器、初创企业自动化运维、区级政务等保合规等目标场景，Appliance 提供了一条清晰的硬件最后防线部署路径。

"让每一台服务器，拥有自主免疫能力。"

— AetherGuard —

AetherGuard 大学生创新创业项目组

杭州视界奇点科技有限公司